

[doc. web n. 10118395]
Provision of February 13, 2025
Register of Provisions
n. 70 of February 13, 2025

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Dr. Claudio Filippi, Deputy Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter, "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter
"Code");

HAVING REGARD to Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers entrusted to the Guarantor for the
protection of personal data, approved by
Resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc.
web n. 9107633 (hereinafter "Guarantor Regulation
No. 1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of the Guarantor Regulation
No. 1/2000 on the organization and functioning of the
office of the Guarantor for the protection of personal data, doc. web n. 1098801;

Rapporteur Dr. Agostino Ghiglia;

PREMISE

1. Introduction.

With a complaint submitted pursuant to Article 77 of
the Regulation, Dr. XX, who works at the ULSS 9 Scaligera
Company (hereinafter "Health Company"), reported
that "on XX [...] he received a
disciplinary measure [...]. The measure for
the application of the sanction was communicated

by the UOC General Affairs and the UOS Disciplinary Proceedings to the Human Resources Management office and [the] office [of the complainant...] (UOS Training) via protocol in a manner accessible to all employees (about 50-60)".

2. The investigative activity.

In response to a request for information from the Authority (see note of XX, prot. n. XX), the Health Company, with note of XX (prot. n. XX), declared, in particular, that:

"the concluding measure of the disciplinary proceeding was registered in compliance with the provisions contained in the DPR of December 28, 2000, n. 445 "Consolidated text of legislative and regulatory provisions on administrative documentation" and the Manual for the Management of the Electronic Protocol, Document Flows, and Archives of the ULSS 9 Scaligera Company, approved by Resolution of the General Director n. XX of XX, as well as the [Company] Regulation for disciplinary proceedings for staff in the sector";

"due to a mere material error by the operator who carried out the registration, the personal data of the interested party were included in the subject of the protocol. Similarly, the measure was erroneously attached to the protocol, although in a non-integral form";

"the final measure was registered by an employee, specifically authorized for this activity, of the UOC General Affairs to which the UOS Disciplinary Proceedings belongs, and subsequently assigned for competence to the UOC Human Resources, for the subsequent obligations, and for information to the UOS Training, the structure to which the interested party belongs, as provided by the company regulation";

"the particular accessibility by all operators belonging to the UOS Training to the protocols assigned to the structure was arranged on specific indication of the previous director of the same, considering their small number, to ensure the continuity of service in case of unplanned absences";

"following the report of the interested party, with note prot. XX of XX, it was decided, immediately and verbally, to immediately limit accessibility to the registered document, with resulting visibility solely by the Disciplinary Proceedings Office and the concurrent analysis of the incident in terms of compliance with the rules on the protection of personal data";

"paragraph 9 of the Regulation for disciplinary proceedings for staff in the sector at point 2 establishes that, in the case of disciplinary measures,

“the transmission takes place in a confidential manner”;
“upon receiving the report from the interested party on XX, the privacy officer's structure was involved, which took over the communication for the appropriate checks. Following these and establishing the material error of the registrar that enabled the complained dissemination of personal data, the incident was assessed as a violation of personal data and the appropriate company procedure was activated”;

“Considering the particular sensitivity regarding the incident highlighted by the interested party, the undersigned, although not being obligated under paragraph 3 of Article 34 of EU Regulation 2016/679, and following the proposals of the DPO, deemed it appropriate to send the interested party on XX a letter of response and apology mentioned in your communication”;

“Subsequently, following the note from the acting Director of General Affairs, no. XX of XX, after contacting the company Privacy Officer and the company Data Protection Officer, an audit was conducted, in the presence of the undersigned, on XX, the final report of which was acquired under protocol no. XX of XX”;

“As a result of the Audit findings, the following actions were taken: to remind all authorized individuals operating on the protocol system of the necessity to strictly adhere to the principle of data minimization, particularly regarding the subject of the protocol [and] to initiate a thorough review of the protocol ‘tree’, in order to prevent the recurrence of similar security incidents, scheduling a series of meetings with the individual units profiled in the company protocol for a reassessment of the protocol and assignment methods”;

“In light of the communication from the Authority, it was necessary to verify whether the aforementioned security measures were sufficient to inhibit access to the communication of the provision beyond those reported in the note of XX”;

“Unfortunately, it emerged that the aforementioned technical measure of ‘immediate limitation of accessibility to the recorded document, with consequent visibility only by the Office of Disciplinary Proceedings’, promptly adopted in XX and then verified, was no longer operational, due to a further material error at the system manager level”;

“Upon becoming aware of this circumstance, action was taken to operate again on the protocol system through the system administrator to restore the block and to reopen the data breach procedure.”

With a note dated XX (protocol no. XX), the Office, based on the elements acquired, the checks carried out, and the facts emerged following the investigative activity, notified the Health Authority pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation for having “attached to the protocol, even if in a non-integral form” the concluding provision of the disciplinary procedure against the complainant, thereby making it visible to other parties (in particular, all employees of UOC Human Resources and UOC Training) not specifically authorized to process the information contained therein, in the absence of an appropriate legal basis, in violation of Articles 5 and 6 of the Regulation, as well as Article 2-ter of the Code. Furthermore, it emerged that personal data of the interested party were already present in the subject of the recorded document, albeit inserted “due to mere material error by the operator who carried out the recording.”

With the same note, the aforementioned holder was invited to submit defensive writings or documents to the Authority or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph 1, of Law No. 689 of November 24, 1981).

With a note dated XX (protocol no. XX), the Health Authority submitted a defensive memorandum, stating, in particular, that:

“the activity of thorough review of the protocol tree has continued, and numerous meetings with the

individual interested units have been scheduled and carried out in the current year”;

“In particular, the access structure to the protocol of the UOS Training has been redefined, in conjunction with the reorganization of the service, so that the visibility of the correspondence sent to the responsible person is now visible only to the responsible person himself and to another employee with secretarial functions, thus correcting the possibility that the protocols were visible to all seven employees of the unit since, prior to the reorganization, in the absence of a clear division of tasks, all staff potentially had to manage all office practices”;

“Organizational charts related to UOC General Affairs have also been verified, with particular attention to the sections dealing with disciplinary proceedings and to UOC Human Resources Management, the latter already having a very limited and differentiated organizational chart, so that the knowledge of the disciplinary provision was limited, following the sending via protocol, to the direction of the Unit and to the Staff Office which includes only the Director of the Unit, for a total of 4 employees”;

“A procedural operation has been defined and approved that acknowledges the indications already given for the communication process related to disciplinary proceedings [...] and regarding training [...] a series of mini-courses in video streaming are being developed to be published on the company intranet site in order to improve preparation, awareness, and attention to the use of the protocol”;

“An evaluation of the current solutions available on the market has been carried out, favoring those in ‘Reuse’ developed by other public entities available in the AgID catalog, as provided for by Chapter VI of the Digital Administration Code (CAD). This activity has become necessary in order to be able to use more suitable software.”

****Duties, Simple and Effective, Also from the Perspective of Data Protection, Compared to the Current One****

“A network of references for data protection has been created, which includes personnel from the main structures of the ULSS Company. This structure is governed by the Data Protection Officer and is typically convened once a month to share and enhance knowledge on privacy-related issues and to disseminate this knowledge widely, as well as to proactively intercept and address any potential risks to data protection.”

The Health Authority, furthermore, during the hearing, pursuant to Article 166, paragraph 6, of the Code, represented that (see minutes prot. no. XX of XX):

“the review of the protocol tree is ongoing; following the personal data breach involving Westpole S.p.a., the review of the user assignment procedure has been accelerated, resulting in the deactivation of users, reducing from approximately 1,500 users to about 200”;

“thanks to the contribution of the Data Protection Officer, on XX a review of the operational instructions for disciplinary procedures was carried out; on XX an additional review was conducted, and currently, another one is underway”;

“the Company continues to demonstrate a constant commitment to training authorized protocol operators in the processing of personal data for the benefit of approximately 7,000 employees, also through specific and targeted training interventions”;

“a new software is in the process of being acquired, although activities related to its implementation are currently slowed down by some personal data breaches involving external data processors”;

“with regard to the technical and organizational measures provided by the current protocol management software, audit activities have been carried out and have guided the Company’s choices regarding the adoption of the new software; those related to the new software are postponed until its final acquisition”;

“all members of the Human Resources UOC are involved in training and awareness activities aimed at minimizing the risk of errors in the management of the IT protocol and, in general, in the management of all other administrative acts concerning the employed personnel, including disciplinary procedures.”

****3. Outcome of the Investigative Activity.****

****3.1 The Regulatory Framework.****

The regulation on the protection of personal data provides that public entities, even when acting in the

performance of their duties as employers, may process personal data of workers if the processing is necessary, in general, for the management of the employment relationship and to fulfill specific obligations or tasks provided for by national sector regulations (Articles 6, paragraph 1, letter c), 9, paragraphs 2, letter b), and 4, and 88 of the Regulation) or “for the performance of a task carried out in the public interest or related to the exercise of public powers vested in the data controller” (Article 6, paragraph 1, letter e), of the Regulation).

Such processing must be based on Union or Member State law, which must pursue a public interest objective and be proportionate to the pursuit of the same. The purpose of the processing must be necessary for the execution of a task carried out in the public interest or related to the exercise of public powers.

The employer, as the data controller, is, in any case, required to comply with the general principles regarding the protection of personal data (Article 5 of the Regulation) and must process the data through “authorized” and “trained” personnel regarding access and processing of data (Articles 4, point 10), 29, and 32, paragraph 4, of the Regulation).

****3.2 The Processing of Personal Data through the IT Protocol System.****

As is well known, since 2007, the Guarantor has clarified that the administration must adopt technical and organizational measures to prevent the unjustified knowledge of personal data of its employees by other colleagues or third parties, in order to avoid the improper circulation of personal information, not only externally but also within the workplace among unauthorized subjects. This is because making data available to subjects who, although part of the data controller's organization, cannot be considered “authorized” to process (see Articles 4, no. 10, 28, paragraph 3, letter b), 29, and 32, paragraph 4, of the Regulation, as well as Article 2-quaterdecies of the Code), due to their role and functions exercised within that organization, may lead to a communication of personal data without a legal basis (see points 2, 4, 5.1, and 5.3 of the “Guidelines on the Processing of Personal Data of Workers for Employment Relationship Management in the Public Sector,” of June 14, 2007, published in G.U. July 13, 2007, no. 161, and at www.garanteprivacy.it, doc. web no. 1417809).

In this regard, according to the consolidated orientation of the Guarantor, recently confirmed in numerous provisions on individual cases, the personal data of employees cannot be disclosed to subjects other than those who are part of the specific employment relationship, taking into account the definitions of “personal data” and “data subject,” the following measures:

1. **Imposition of Administrative Fine**

The Garante, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the authority to impose an administrative fine as per Article 83, in addition to other corrective measures outlined in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case.

2. **Consideration of Circumstances**

In determining the amount of the fine, the Garante shall take into account the nature, gravity, and duration of the infringement, the intentional or negligent character of the infringement, any actions taken by the controller or processor to mitigate the damage suffered by data subjects, the degree of responsibility of the controller or processor, any previous infringements by the controller or processor, the degree of cooperation with the supervisory authority, and the categories of personal data affected by the infringement.

3. **Final Decision**

The Garante shall issue a final decision regarding the imposition of the administrative fine and any additional sanctions, ensuring that the decision is proportionate to the infringement and takes into account the mitigating factors presented by the controller.

4. **Notification of Decision**

The decision shall be communicated to the parties involved, providing them with the opportunity to appeal the decision in accordance with applicable laws.

5. ****Implementation of Corrective Measures****

The Garante may also require the implementation of specific corrective measures to ensure compliance with the Regulation and the protection of personal data.

6. ****Conclusion****

In light of the above considerations, the Garante confirms the preliminary assessments of the Office and finds the processing of personal data carried out by the Azienda Sanitaria to be unlawful for having conducted personal data processing without a legal basis, in violation of Articles 5, 6 of the Regulation, as well as Article 2-ter of the Code.

7. ****Final Remarks****

Given that the violation of the aforementioned provisions occurred as a result of a single conduct (the same processing or interrelated treatments), Article 83, paragraph 3, of the Regulation applies, under which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Considering that, in this case, the most serious violations related to Articles 5, 6 of the Regulation, as well as 2-ter of the Code, are subject to the sanction provided for in Article 83, paragraph 5, of the Regulation, as referenced also by Article 166, paragraph 2, of the Code, the total amount of the sanction is to be quantified up to €20,000,000.

8. ****Final Decision on Corrective Measures****

In this context, considering that the conduct has exhausted its effects and taking into account the organizational and technical measures implemented by the Azienda Sanitaria, the conditions for the adoption of further corrective measures pursuant to Article 58, paragraph 2, of the Regulation do not exist.

9. ****Adoption of the Order for the Application of the Administrative Pecuniary Sanction and Accessory Sanctions****

The Garante, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to impose an administrative pecuniary sanction as per Article 83, in addition to other corrective measures outlined in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case.

This concludes the translation of the legal document text.

the injunction order, which also provides for the application of the administrative sanction of its publication, in whole or in part, on the website of the Authority pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019).

In this regard, taking into account Article 83, paragraph 3, of the Regulation, in this specific case, the violation of the cited provisions is subject to the application of the administrative pecuniary sanction provided for by Article 83, paragraph 5, of the Regulation.

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for by Article 83, paragraph 2, of the Regulation.

Considering that:

- with specific regard to the nature, severity, and duration of the violation, it should be noted that the processing occurred in relation to the personal data of only one worker (Article 83, paragraph 2, letter a), of the Regulation);
- with specific regard to the subjective profile, the violation was committed following a mere material error in the management of activities related to the IT protocol (Article 83, paragraph 2, letter b), of the Regulation);
- the processing involved very sensitive data related to the complainant's employment in reference to a disciplinary procedure (cf. Article 83, paragraph 2, letter g), of the Regulation),

it is believed that, in this case, the level of severity of the violation committed by the data controller is medium (cf. European Data Protection Board, "Guidelines 4/2022 on the calculation of administrative pecuniary sanctions pursuant to the GDPR" of May 24, 2023, point 60).

That being said, it is believed that, for the purposes of quantifying the sanction, the following circumstances should be taken into consideration:

- the Health Authority has offered, from the outset, good cooperation with the Authority during the investigation (Article 83, paragraph 2, letter f), of the Regulation);
- there are some previous violations, even if in a different context (Article 83, paragraph 2, letter e), of the Regulation);
- the violation occurred during a period characterized by numerous organizational difficulties, particularly for Health Authorities, related to the issues of the emergency period characterized by the spread of the Sars-cov 2 virus (Article 83, paragraph 2, letter k), of the Regulation).

In light of the aforementioned elements, evaluated as a whole, it is believed to determine the amount of the pecuniary sanction at the sum of 4,000 euros (four thousand) for the violation of Articles 5, 6 of the Regulation, as well as Article 2-ter of the Code, as an administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also believed that, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019, the publication of this section containing the injunction order on the Authority's website should proceed. This is in consideration of the sensitivity of the information subject to processing concerning the vaccination status of certain workers.

Finally, it is noted that the conditions of Article 17 of Regulation No. 1/2019 are met.

ALL OF THE ABOVE HAVING BEEN STATED, THE AUTHORITY declares, pursuant to Article 57, paragraph 1, letter f), of the Regulation, the unlawfulness of the processing carried out by the ULSS No. 9 Scaligera for violation of Articles 5 and 6 of the Regulation, as well as Article 2-ter of the Code, in the terms stated in the reasoning;

ORDERS

The ULSS No. 9 Scaligera, represented by the pro tempore legal representative, with registered office at Via Valverde, 42 - 37122 Verona (VR) C.F. 02573090236, to pay the sum of 4,000 euros (four thousand) as an administrative pecuniary sanction for the violations indicated in the reasoning.

It is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

ENJOINS

The aforementioned Health Authority, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of 4,000 euros (four thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of subsequent executive acts in accordance with Article 27 of Law No. 689/1981;

DISPOSES

- pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019, the publication of the injunction order on the Authority's website;
- pursuant to Article 154-bis, paragraph 3 of the Code and Article 37 of the Regulation of the Authority No. 1/2019, the publication of this provision on the website of the Authority;
- pursuant to Article 17 of the Regulation of the Authority No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Articles 78 of the Regulation, 152 of the Code, and 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, February 13, 2025

THE PRESIDENT
Stanzione

THE REPORTER

Ghiglia

THE DEPUTY SECRETARY GENERAL

Filippi